

MLSecOps

INTRODUCTION

TO THE COURSE

دکتر محمد فزونی

در این جلسه موارد زیر رو می‌گم:

- چندتا آمار و سپس ارتباط با MLSecOps و اینکه چرا امنیت باید مهم باشه برامون
- راجع به سرفصل‌ها و ابزارها، کمی صحبت می‌کنم
- کتاب‌های که قرار استفاده بشه و اون‌هایی که خیلی مفیدن براتون رو می‌گم
- چگونه یک معماری سرویس بر مبنای امنیت را طراحی می‌کنیم؟
- با رعایت این موارد 100% مصون هستیم؟
- چند نکته کلی ..

چرا امنیت باید در صدر باشد؟

چند اسلاید آمار بشما نشان می‌دهم و سپس ارتباط با MLSecOps رو میبینیم.
ممکن است برخی از اصطلاحات فعلن برای شما ناآشنا باشند.

چرا امنیت باید در صدر باشد؟

چند اسلاید آمار بشما نشان می‌دهم و سپس ارتباط با MLSecOps رو میبینیم.
ممکن است برخی از اصطلاحات فعلن برای شما ناآشنا باشند.

Omdia executed a survey of 400 IT, cybersecurity, and application professionals at organizations in North America responsible for evaluating or purchasing technology products and services to secure their organization's software supply chain.

چرا امنیت باید در صدر باشد؟

بیشترین نگرانی‌های امنیتی حال حاضر کمپانی‌ها

Rank	Concern	%
1	AI technology (GenAI + LLM data security)	40%
2	Third-party & OSS code	39%
3	Software dependencies	38%
4	Cloud Service Provider infrastructure	24%
5	Infrastructure-as-Code (IaC)	23%

OSS (Open-Source Software)= free, public code that everyone uses but you don't always know if it's safe.

بیشترین حوادث رخ داده در 12 ماه گذشته

Incident Type	%
Exploit of known vulnerability in third-party code	27%
Zero-day exploit	23%
Zero-day supply chain attack	20%
Stolen secrets from source code repos	20%
Attacks on developer AI tools	19%
Misconfigured cloud service exploit	19%
CI/CD pipeline flaws	18%
Developer tool flaws (IDE, etc.)	17%
Ransomware in supply chain	15%
Repository flaws (GitHub/GitLab)	15%

بیشترین حوادث رخ داده در 12 ماه گذشته

Incident Type	%
Exploit of known vulnerability in third-party code	27%
Zero-day exploit	23%
Zero-day supply chain attack	20%
Stolen secrets from source code repos	20%
Attacks on developer AI tools	19%
Misconfigured cloud service exploit	19%
CI/CD pipeline flaws	18%
Developer tool flaws (IDE, etc.)	17%
Ransomware in supply chain	15%
Repository flaws (GitHub/GitLab)	15%

Zero-day exploit means:

An attack that uses a security hole that nobody knew existed. So, there's zero days of warning or time to fix it before it's used.

تاثیر روی کسب و کارها حاصل از حوادث

Impact	%
Unauthorized access to apps/data	46%
SLA disruptions due to remediation	37%
Stolen developer credentials/secrets/keys	35%
Data loss	27%
Malware/ransomware injection	24%
Compliance fines	23%

تأثیر روی کسب و کارها حاصل از حوادث

Impact	%
Unauthorized access to apps/data	46%
SLA disruptions due to remediation	37%
Stolen developer credentials/secrets/keys	35%
Data loss	27%
Malware/ransomware injection	24%
Compliance fines	23%

"SLA disruptions due to remediation" means:

While the security team is fixing a hack or vulnerability, the service goes down or slows down, breaking the promise to customers.

بحران مفید بودن ابزارها

👉 The only effective tool:

- Secure container services and hardened container image libraries.

😬 All others fell short:

- including **SCA**, **SAST**, **DAST**, **SBOM** tools, etc.



یکم زیادی جوگیر شدن



سرمایه‌گذاری‌های سازمان‌ها و اولویت‌هایشان

- 62% plan significant investments in Supply Chain Security (*One Important Area*)
- 98% prioritize enabling developers to secure their own code (*Emphasize on Learning and Level-Up*)
- But 45% of security teams have only moderate or less influence over developer security processes. *Almost half of security teams don't have real authority over developers; so, security gets skipped for speed.*

چند مثال ملموس تر و واقعن نگران کننده 🧐

- تزریق بدافزار به مخازن عمومی (مثل npm و PyPI):
هکرها با انتشار بسته‌های مخرب با نام‌های مشابه (Typosquatting)، به راحتی به سیستم توسعه‌دهندگان نفوذ می‌کنند.
در سال ۲۰۲۵، تعداد بسته‌های مخرب npm ۴۵۱٪ افزایش یافت و به بیش از ۱۷۱,۰۰۰ بسته رسید 🤖 (npm پکیج‌منجر JavaScript است).
- آلودگی محیط ساخت (Build Pipeline):
مهاجمان با دسترسی به سرورهای CI/CD یا دزدیدن توکن‌های انتشار، کد مخرب را در لحظه‌ی ساخت به برنامه تزریق می‌کنند. حمله تاریخی SolarWinds در دسامبر ۲۰۲۰ که به ۱۸,۰۰۰ سازمان نفوذ کرد، نمونه بارز این روش است.
- سوءاستفاده از تصاویر کانتینری (Container Images):
این یک تهدید رو به رشد است. مهاجمان یا تصاویر پایه جعلی با نام‌های مشابه منتشر می‌کنند یا خط لوله ساخت یک تصویر محبوب را آلوده می‌کنند. در یک مورد، یک تصویر جعلی بیش از ۸۰,۰۰۰ بار pull شد.

ارتباط با MLSecOps

Link	Explanation
AI as top threat	40% of participants rank AI as #1 risk MLSecOps = Securing AI Models + Training Data
Attacks on AI tools	19% faced attacks on developer AI tools MLSecOps = Hardening These Tools
AI for defense	Only effective tool (hardened containers) can be enhanced with AI MLSecOps = Using ML to Detect Threats Automatically

سرفصل‌های کورس

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

مقدمات و کار با داکر و
لینوکس

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

کار با کلااد و GitHub-Actions

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

آشنایی و کار با یک صف بسیار
مهم در دنیای دیتا

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

بهترین گزینه برای دلیور
کردن سرویس‌ها

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

آشنایی با بهترین ابزارهای
MLOps

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

آشنایی با بهترین ابزارهای
MLSecOps

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

ترکیب تمامی مطالبی که
آموختیم.

اینجا سعی خواهیم کرد که بهتون بگم که چطوری
یک پلتفرم اختصاصی MLSecOps رو برای
خودمون طراحی و اجرا کنیم.

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

بیشتر از اینکه به تئوری بها
بدهیم، کارهای عملیاتی انجام
خواهیم داد.

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

بیشتر از اینکه به تئوری بها
بدهیم، کارهای عملیاتی انجام
خواهیم داد.

ولی سعی می‌کنیم قبل از
انجام هر کاری، کمی تئوری
بگم.

1 Foundations: OS & Containers

2 CI/CD & Cloud Basics

3 Streaming Pipelines: Kafka

4 Orchestration: Kubernetes

5 ML Operations

6 MLSec Tools

7 Capstone Projects

بیشتر از اینکه به تئوری بها
بدهیم، کارهای عملیاتی انجام
خواهیم داد.

ولی سعی می‌کنیم قبل از
انجام هر کاری، کمی تئوری
بگم.

اما همیشه باید بین این دو یک تعادل ایجاد
کنیم. وگرنه از جایی به بعد پیشرفت خوبی رو
مشاهده نخواهیم کرد.

بیشتر از اینکه به تئوری بها
بدهیم، کارهای عملیاتی انجام
خواهیم داد.

ولی سعی می‌کنیم قبل از
انجام هر کاری، کمی تئوری
بگم.

اما همیشه باید بین این دو یک تعادل ایجاد
کنیم. وگرنه از جایی به بعد پیشرفت خوبی رو
مشاهده نخواهیم کرد.

هدف این نیست که کلی ابزار و روش و
تکنولوژی یاد بگیرید. من نگاه شما رو نسبت به
بحث امنیت، باید تغییر بدهم.

ماها باید با مسیر آشنا بشیم. ولی طی کردنش
دیگه از جایی به بعد با خودتون هست.

مطالعه مطالعه مطالعه
تمرین تمرین تمرین
Practice Makes Perfect!

کتاب‌ها

<pack>



1ST EDITION

Adversarial AI Attacks, Mitigations, and Defense Strategies

A cybersecurity professional's guide to AI attacks,
threat modeling, and securing AI with MLSecOps

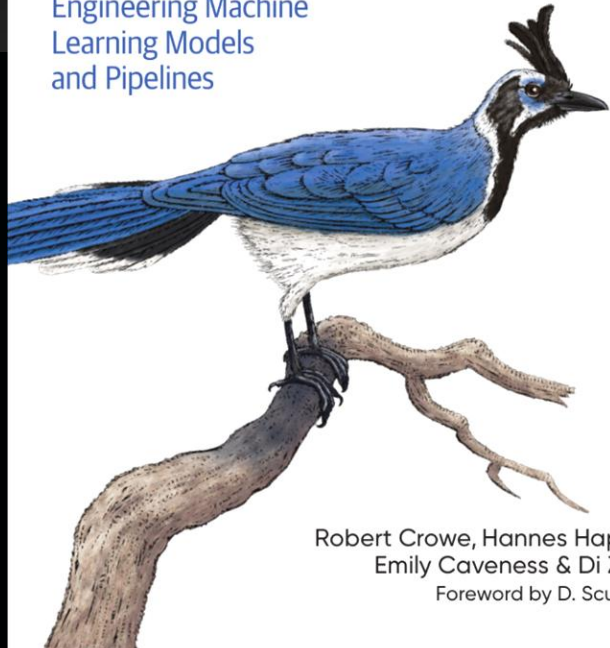
JOHN SOTIROPOULOS



O'REILLY

Machine Learning Production Systems

Engineering Machine
Learning Models
and Pipelines



Robert Crowe, Hannes Hapke,
Emily Caveness & Di Zhu
Foreword by D. Sculley

منبع مطالب
تئوری دوره، این
دو کتاب است!

یک پلت فرم MLOps کامل با
کوهر ساخته می شود. اما
چون نیاز به منابع زیاد دارد
من بیخیال اجرای آن شدم.

Machine Learning on Kubernetes

A practical handbook for building and using a complete
open source machine learning platform on Kubernetes

Faisal Masood | Ross Brigoli

<packt>



1st Edition

Adversarial AI Attacks, Mitigations, and Defense Strategies

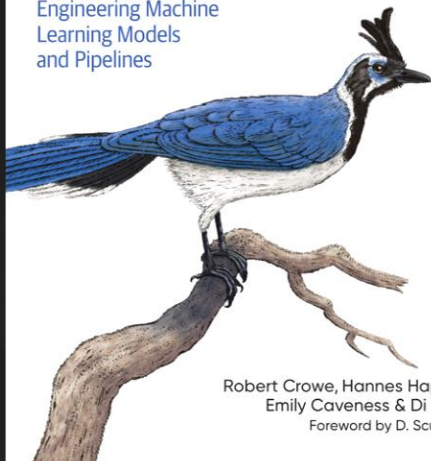
A cybersecurity professional's guide to AI attacks,
threat modeling, and securing AI with MLSecOps

JOHN SOTIROPOULOS

O'REILLY

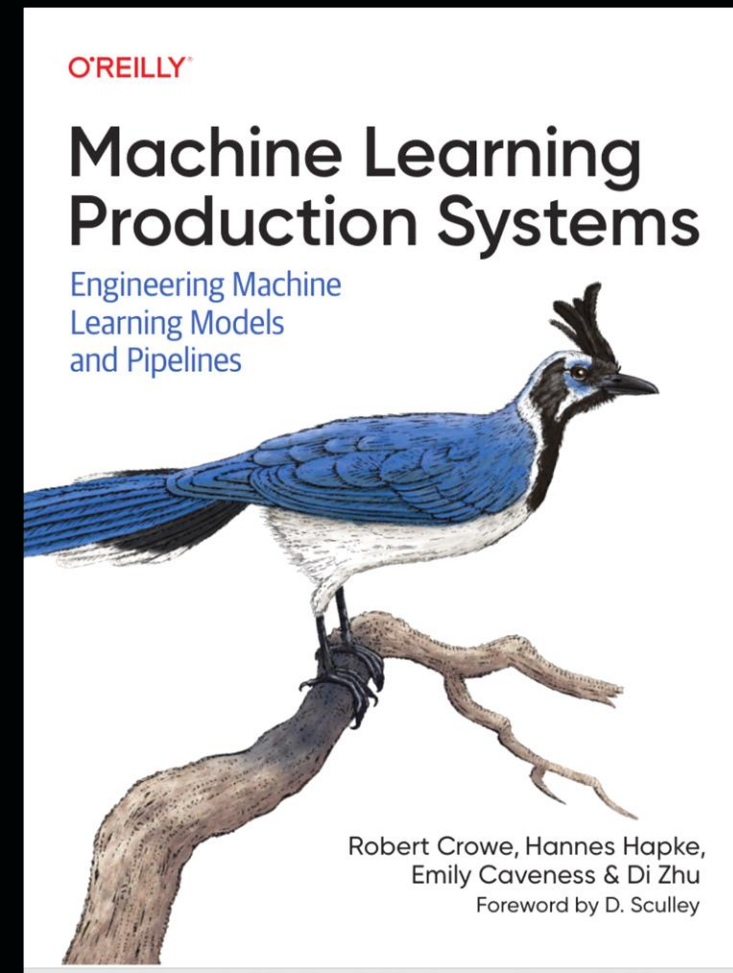
Machine Learning Production Systems

Engineering Machine
Learning Models
and Pipelines

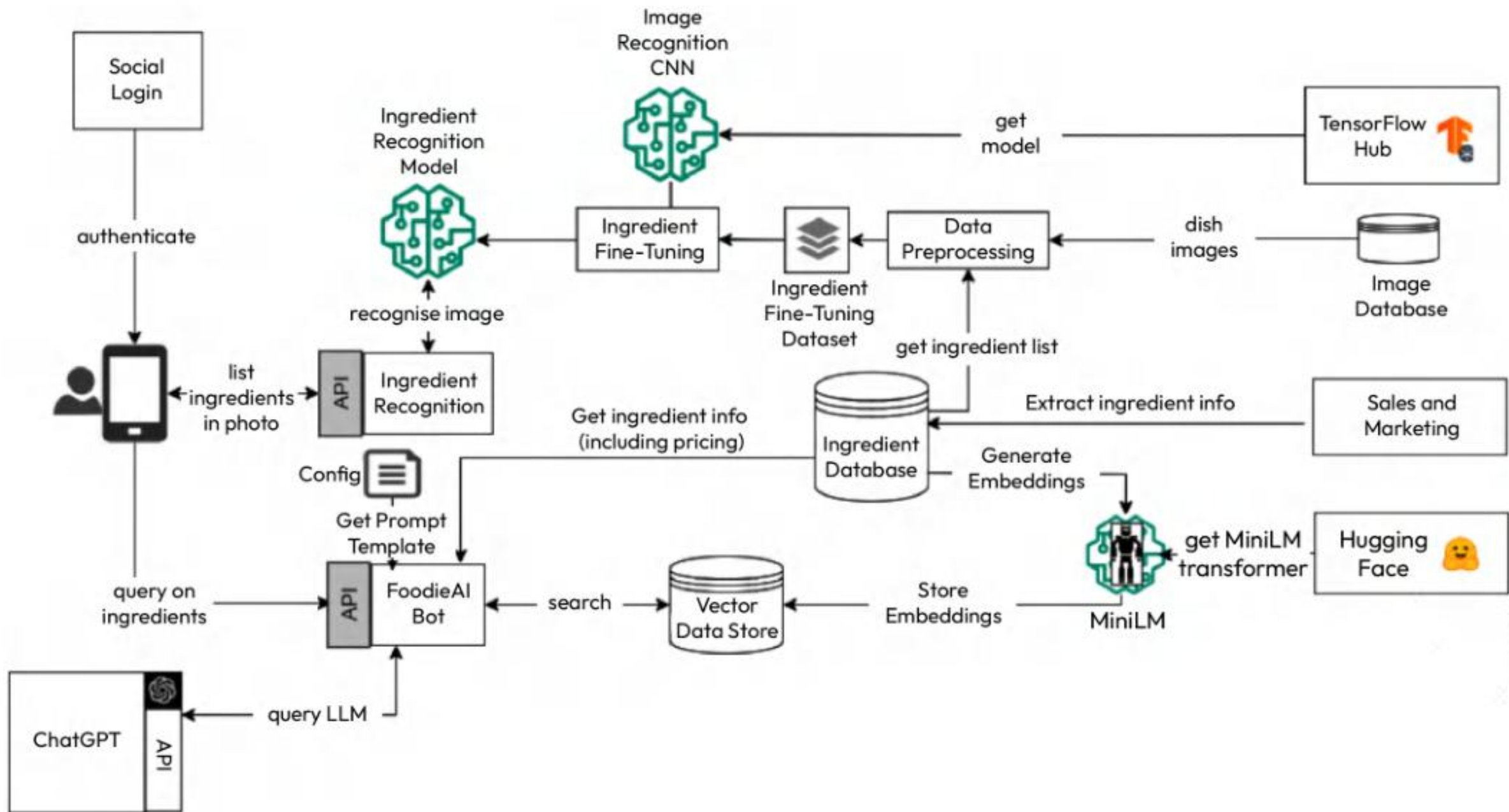


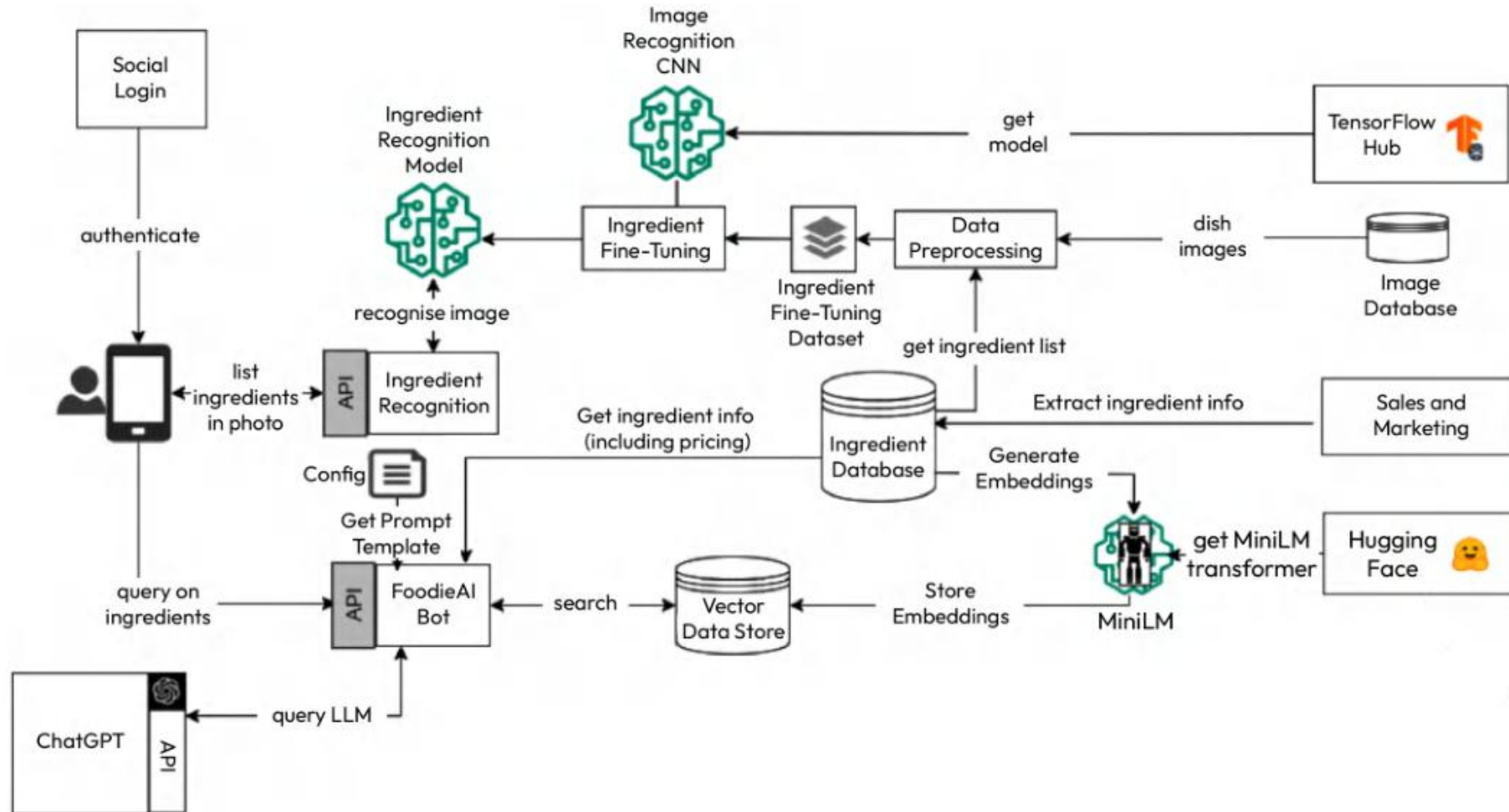
Robert Crowe, Hannes Hapke,
Emily Caveness & Di Zhu
Foreword by D. Sculley

خلاصه منابع اصلی ما اینجا هستند



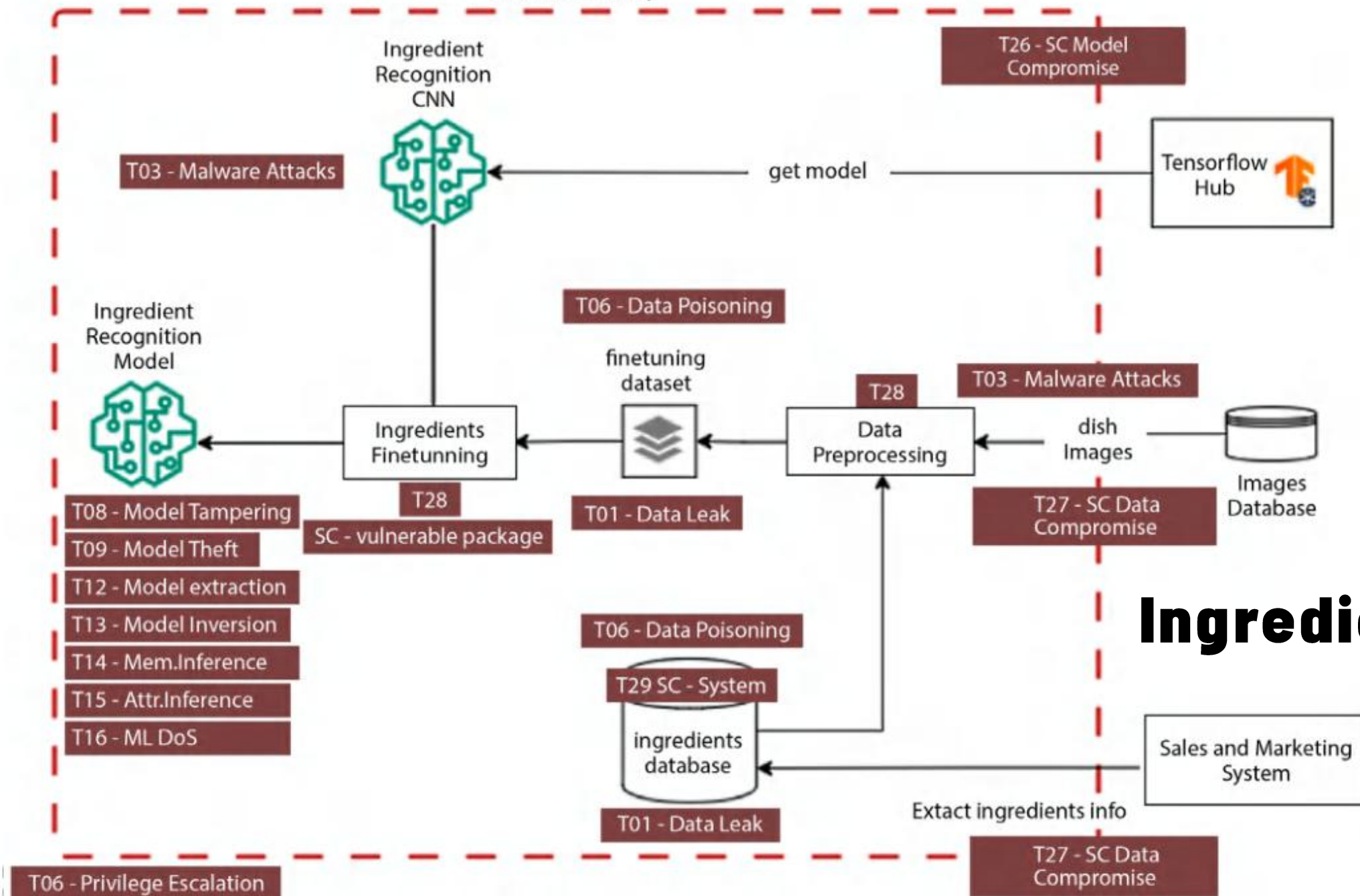
چگونه یک معماری بر مبنای
امنیت را طراحی و اجرا کنیم؟



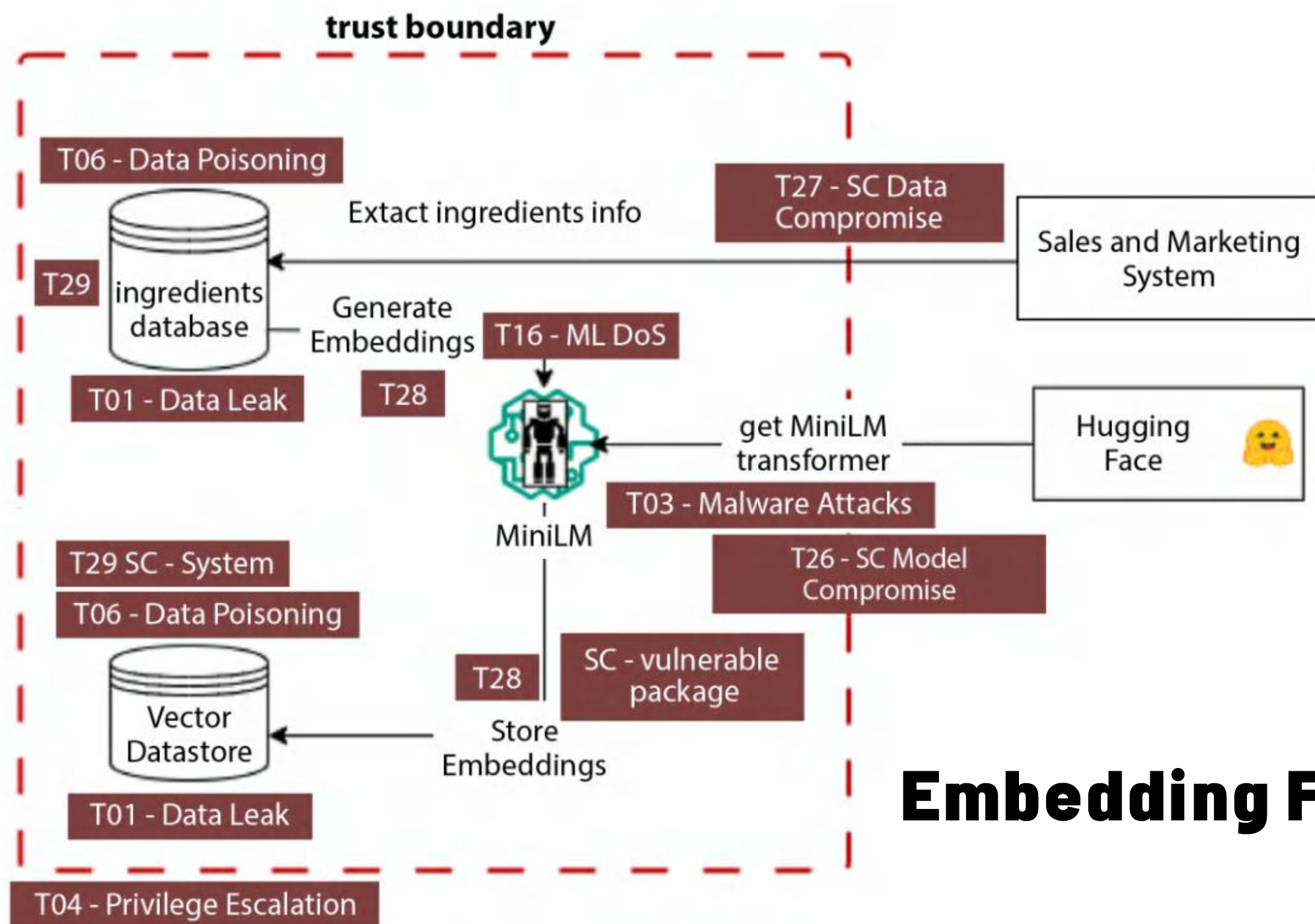


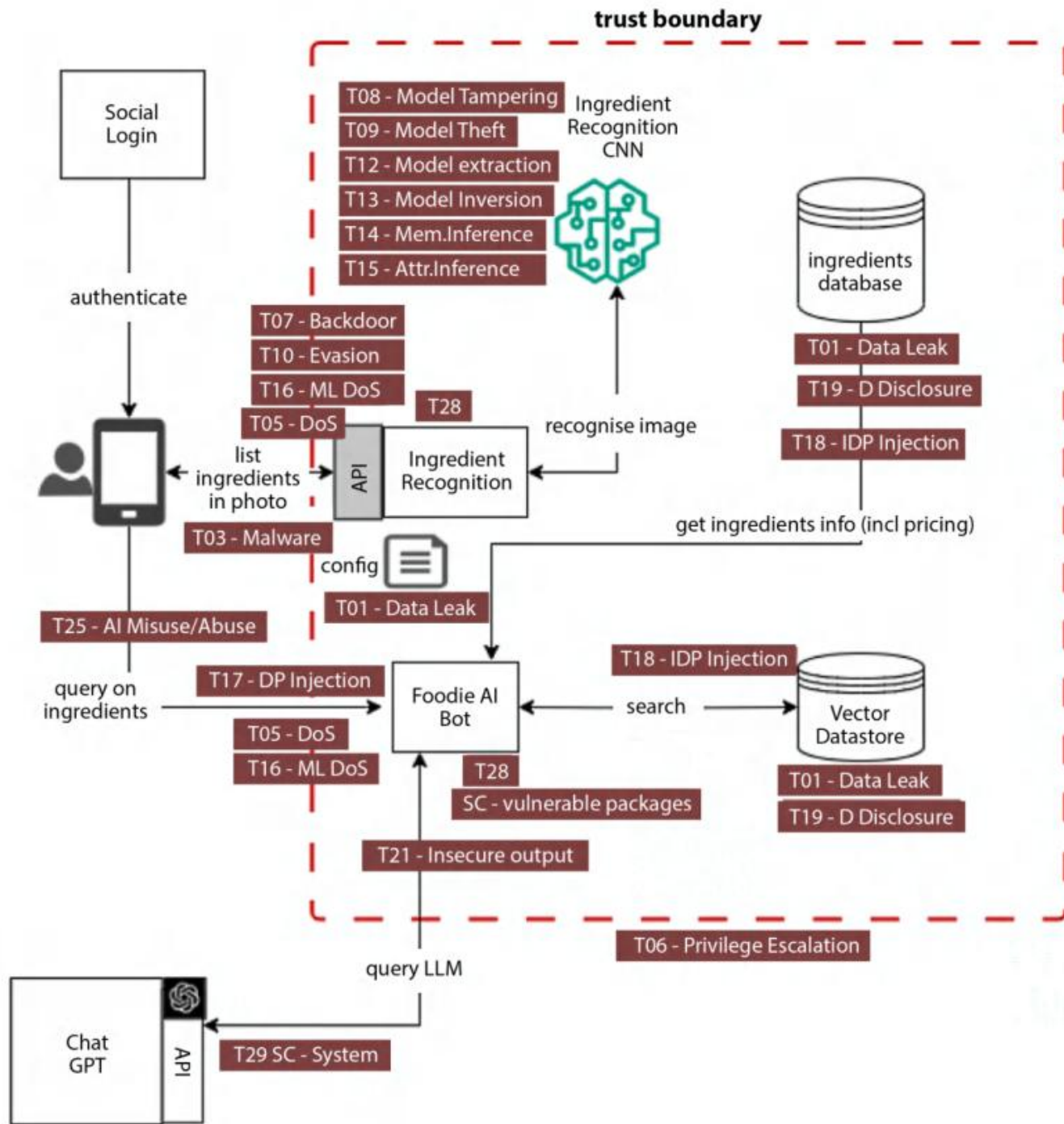
**There are 3 main flows in this architecture.
Based on these, we must design our solution.**

trust boundary



Ingredient Flow





End-User Flow

Id	Attack/Threat	Data Flow/Asset	Likelihood	Impact	Risk
T03	Malware Attacks	Photo Upload	High	High	High
T04	Privilege Escalation	System	High	High	High
T17	Direct Prompt Injection	FoodieAI	High	High	High
T25	AI Misuse/Abuse	FoodieAI	High	High	High
T01	Data Leak	Config, Ingredients Database, Vector Database	High	Medium	Medium
T05	Denial of Service	System	High	Medium	Medium
T16	ML DoS	Ingredients Recognition Service/Model, FoodieAI	Medium	High	Medium
T18	Indirect Prompt Injection	Ingredients Database, Embeddings Vector Store	Low	High	Medium
T19	Data Disclosure	Config, Ingredients Database, Embeddings Vector Store	High	Medium	Medium
T20	Insecure Output	FoodieAI, Ingredients	Medium	High	Medium
T29	Supply Chain System Compromise	OpenAI ChatGPT	Low	High	Medium
T07	Backdoor Attacks	Ingredients Recognition Service/Model	Low	Low	Low
T10	Evasion	Ingredients Recognition Service/Model	Medium	Low	Low
T12	Model Extraction	Ingredients Recognition Service/Model	Low	Low	Low
T13	Model Inversion	Ingredients Recognition Service/Model	Low	Low	Low
T14	Membership Inference	Ingredients Recognition Service/Model	Low	Low	Low
T15	Attribute Inference	Ingredients Recognition Service/Model	Low	Low	Low
T28	Supply Chain Package Vulnerability Exploitation	FoodieAI, Ingredients Recognition Service	Low	Medium	Low

**Now we should
prioritize threats
and then go for
action and coding.**

با رعایت این نکات ضد گلوله
خواهیم شد؟

با رعایت این نکات ضد گلوله خواهیم شد؟

- در دنیای امنیت، ما هر چقدر سرویس خودمون رو مستحکم‌تر بکنیم، در واقع داریم به سیستم پیچیدگی اضافه می‌کنیم.
- پیچیدگی یعنی یکجا حساب کار از دستمون در میره و حفره میزاریم داخل سیستم. کلی هم هزینه به مجموعه تحمیل خواهد شد.
- از اون طرف؛ هیچ سیستمی 100% ضد گلوله نیست. **همه چیز به بودجه‌ی کلاه مشکی‌ها وابسته است.**
- ما با رعایت نکات امنیتی، **زمان و هزینه رو برای اونها بالا** می‌بریم. وگرنه هیچ وقت، هیچ مجموعه‌ای در دنیا نتوانسته ادعای 100% امنیت و غیرقابل نفوذ بودن رو بکند. بخصوص در عصر AI.

با رعایت این نکات ضد گلوله خواهیم شد؟

- در دنیای امنیت، ما هر چقدر سرویس خودمون رو مستحکمتر بکنیم، در واقع داریم به سیستم پیچیدگی اضافه می‌کنیم.
- پیچیدگی یعنی یکجا حساب کار از دستمون در میره و حفره میزاریم داخل سیستم. کلی هم هزینه به مجموعه تحمیل خواهد شد.
- از اون طرف؛ هیچ سیستمی 100% ضد گلوله نیست. همه چیز به بودجه‌ی کلاه‌مشک‌های وابسته است.
- ما با رعایت نکات امنیتی، زمان و هزینه رو برای اونها بالا می‌بریم. وگرنه هیچ وقت، هیچ مجموعه‌ای در دنیا نتونسته ادعای 100% امنیت و غیرقابل نفوذ بودن رو بکند. بخصوص در عصر AI.

باز هم میرسیم به همون شعار همیشگی (البته برای دفاع؛ نه حمله)

Trade-off

چند نکته

مشخصات لپ تاپ من:

Storage

1.14 TB

598 GB of 1.14 TB used

Graphics Card

4 GB

Multiple GPUs installed

Installed RAM

16.0 GB

Speed: 2933 MT/s

Processor

Intel(R) Core(TM)
i7-10750H CPU @
2.60GHz

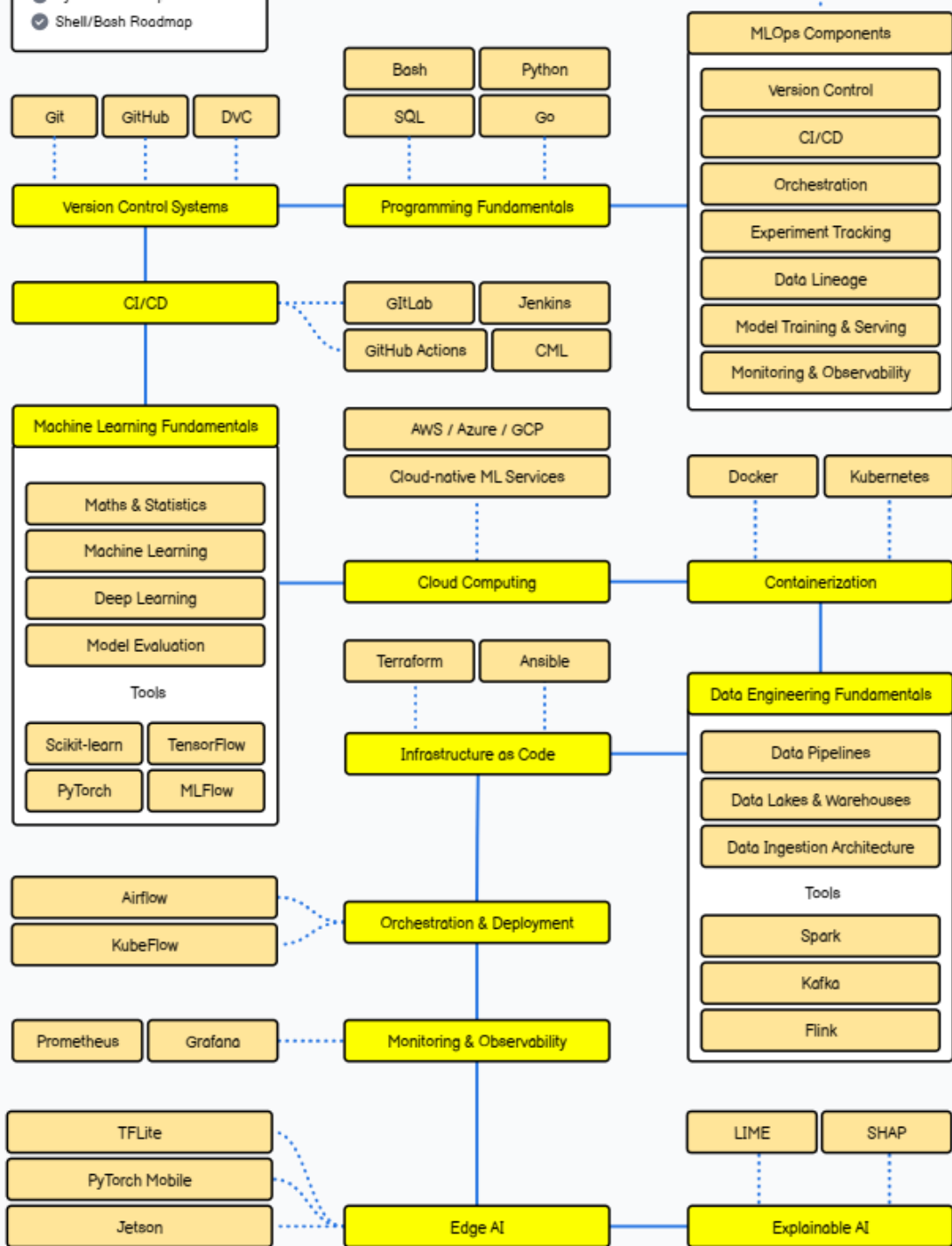
2.59 GHz

- i9 Gen 13 or 14
- 32 or 64 GB RAM (DDR 5)
- 8 GB VRAM
- 1 TB SSD

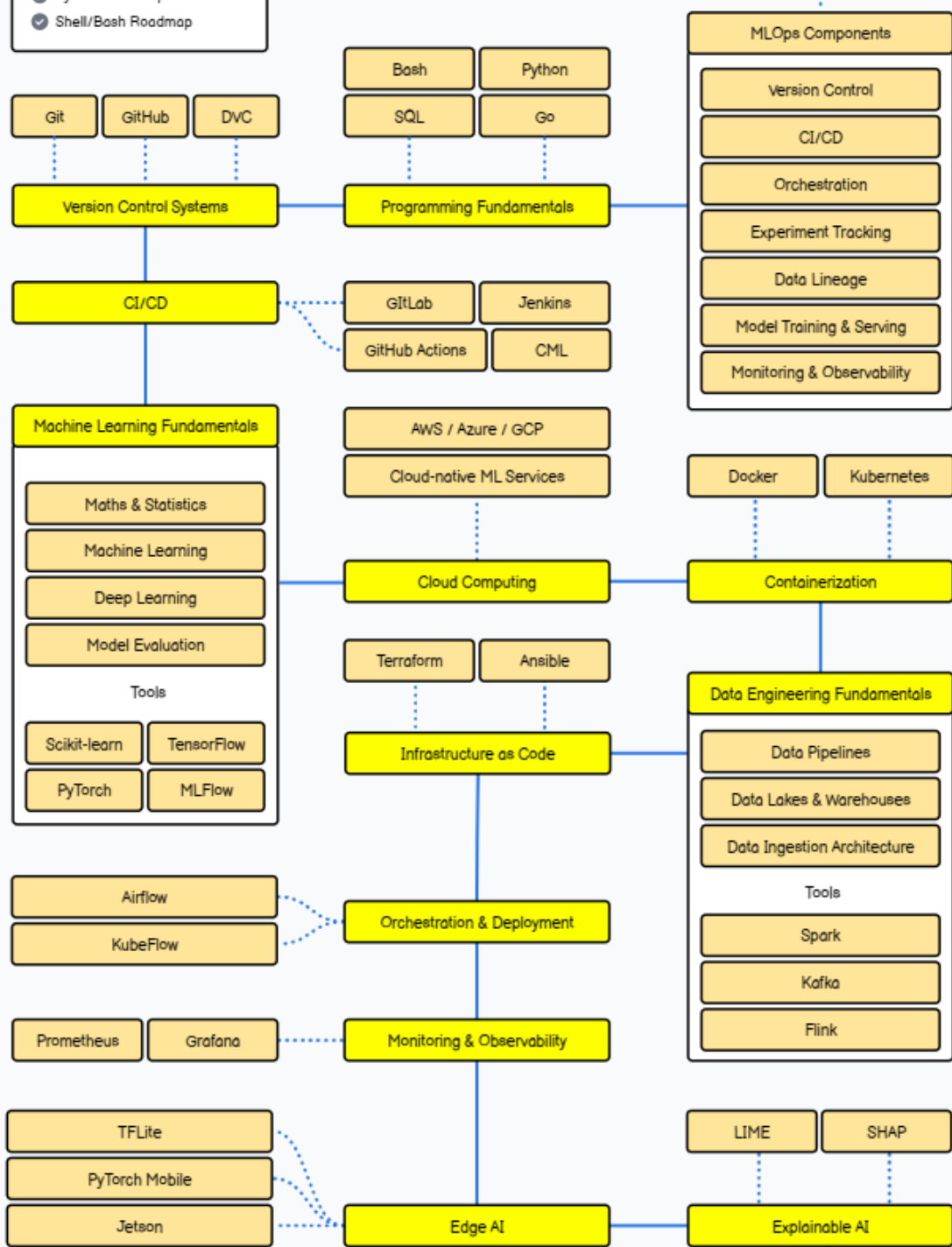


من اینها رو دارم:

- Ubuntu 24.04.4 LTS on WSL (applicable)
 - Windows 11 Pro (main OS)
 - Docker (use a lot)
 - VS Code (use a lot)
 - Python (use a lot)
 - Typora (for .md extensions)
-
- Kali Linux on VirtualBox (for Pen tests, sometimes)
 - Ubuntu 22.04 on Vagrant (spin up multiple VMs)



منبع این رودمپ:
<https://roadmap.sh/mlops>



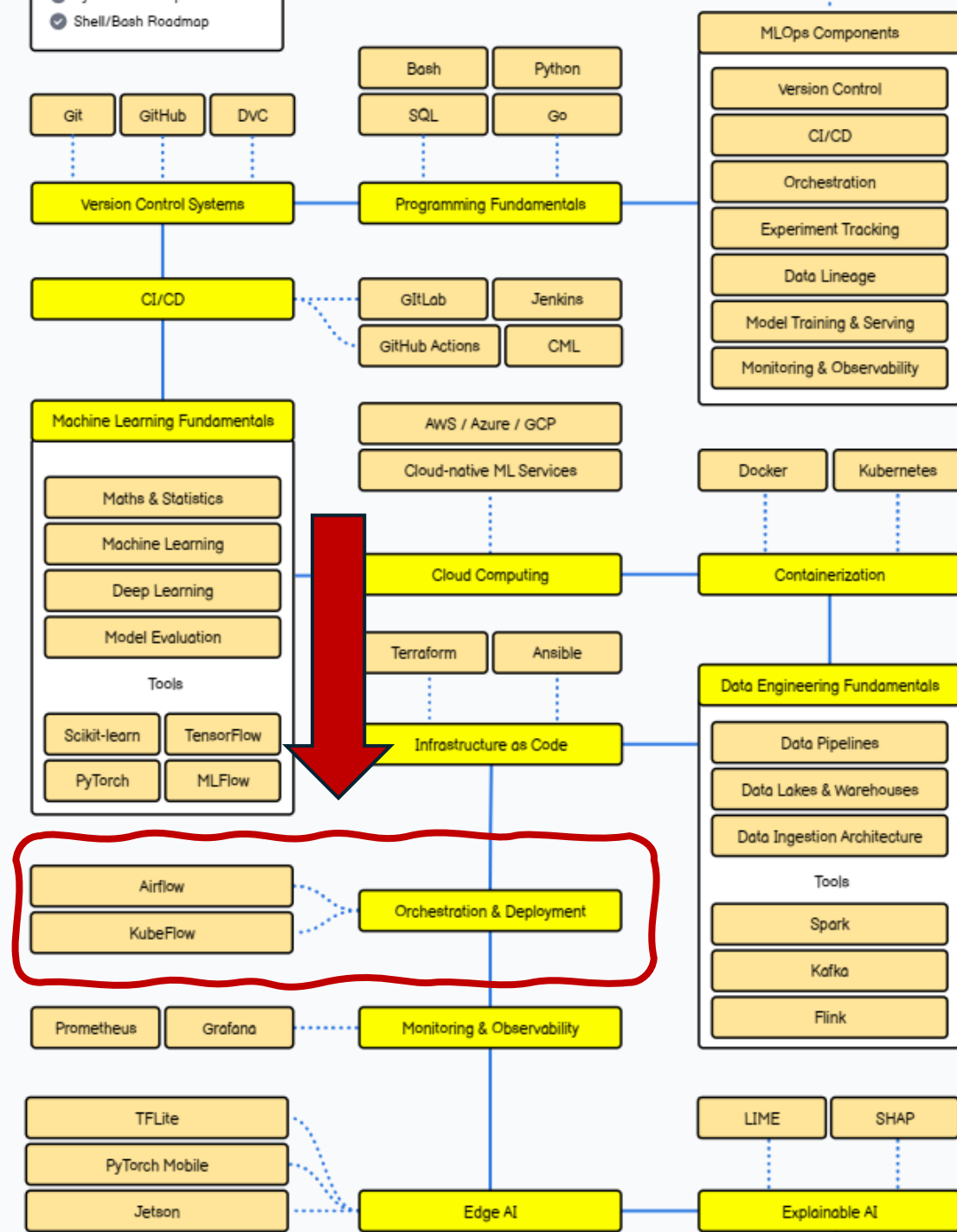
منبع این رودمپ:
<https://roadmap.sh/mlops>

این رودمپ یک
ایراد بزرگ دارد؟

منبع این رودمپ:
<https://roadmap.sh/mlops>

این رودمپ یک
ایراد بزرگ دارد؟

هیچ لایه یا تکنولوژی
خاصی برای بحث
Model Serving
معرفی نشده است.



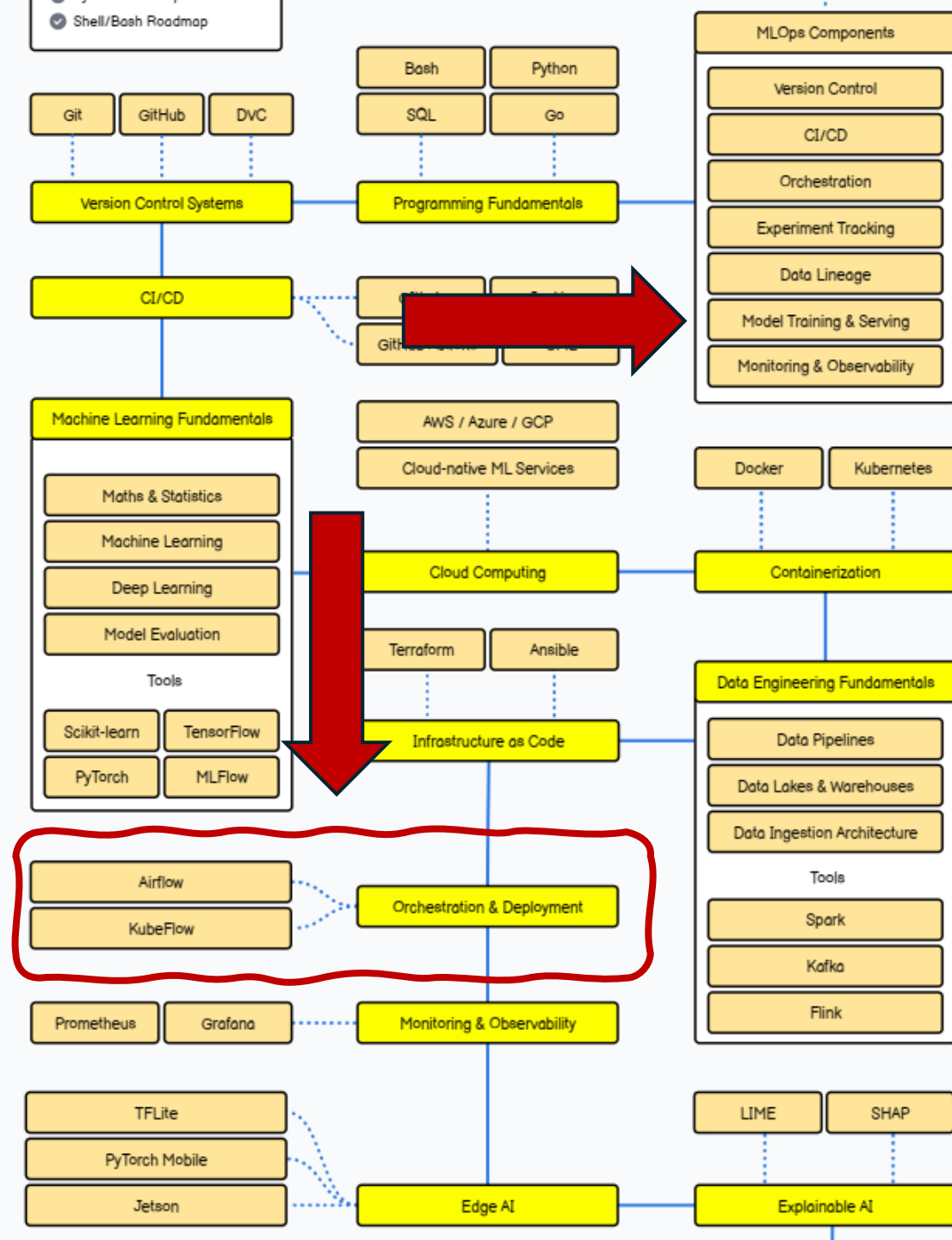
منبع این رودمپ:
<https://roadmap.sh/mlops>

این رودمپ یک ایراد بزرگ دارد؟

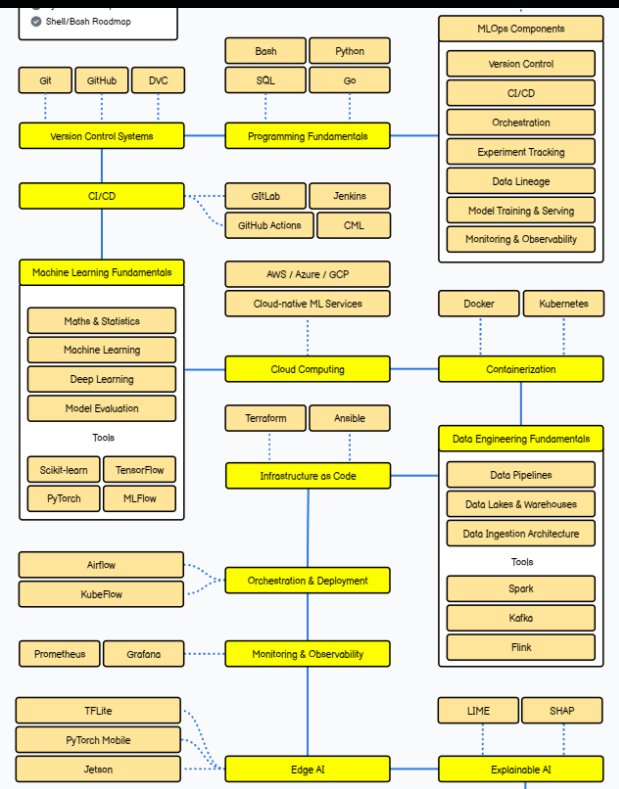
هیچ لایه یا تکنولوژی خاصی برای بحث
Model Serving
معرفی نشده است.

Airflow and KubeFlow

بطور عمده برای ارکستریشن
و آموزش بکار گرفته می‌شن.



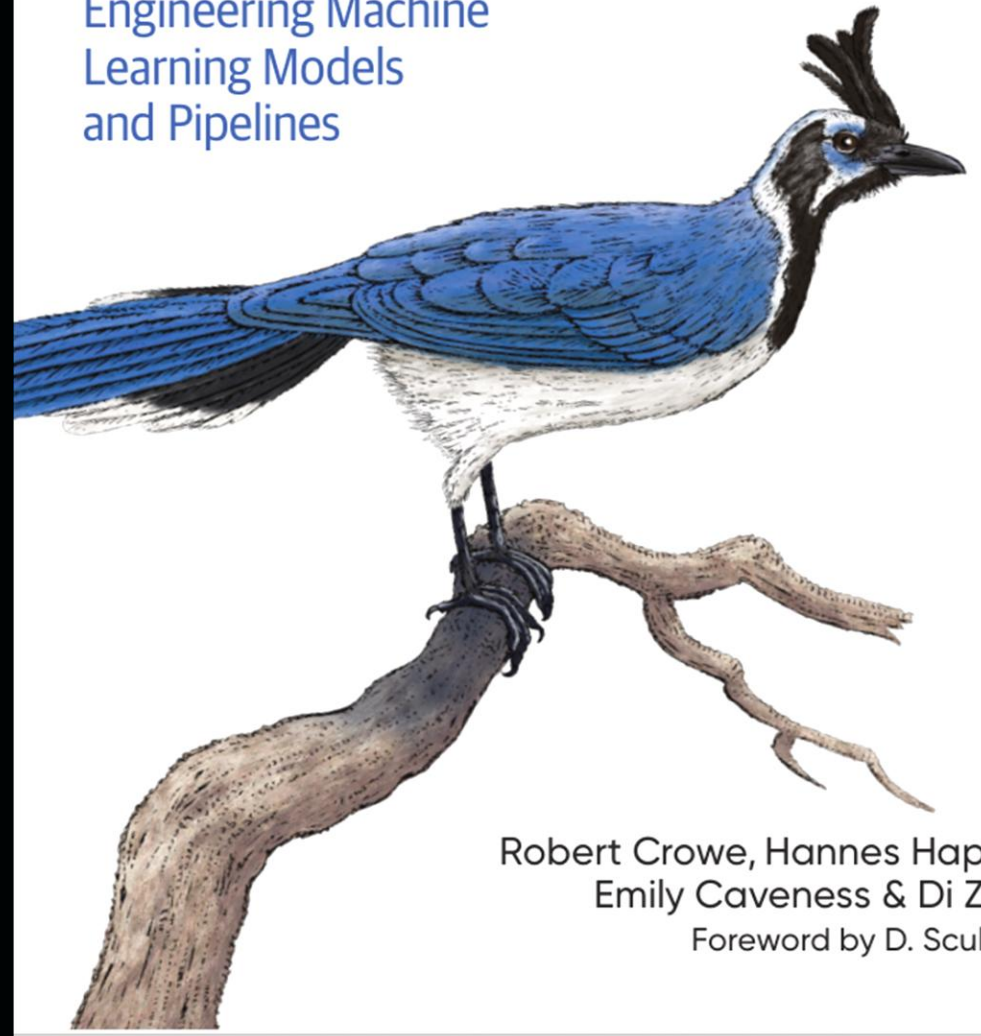
من روش این کتاب رو بهتون می‌گم که
چطوری و بصورت لایه به لایه MLOps رو
بما معرفی می‌کنه. بنظر شخصی بنده،
مسیر واضح‌تر و قابل اجرا تر هست.



O'REILLY®

Machine Learning Production Systems

Engineering Machine
Learning Models
and Pipelines



Robert Crowe, Hannes Hapke,
Emily Caveness & Di Zhu
Foreword by D. Sculley

آروان کلا

زیرساخت یکپارچه ابری و هوش مصنوعی جهانی امن‌تر، سریع‌تر و دردسترس‌تر

با استفاده از زیرساخت یکپارچه، پایدار، امن و هوشمند آروان کلا، بدون دغدغه‌های زیرساختی به وبسایت‌ها و سرویس‌های خود سرعت ببخشید و تجربه‌ی کاربران‌تان را به شکل چشم‌گیری بهبود دهید.

تماس با فروش

شروع کنید

ابر فردوسی



ابر فردوسی : برترین ارائه دهنده رایانش ابری در ایران

با ارائه قدرتمندترین سخت‌افزار ابری

میزبان ۲۰۰۰۰+ کسب و کار و پروژه هستیم.

✓ تحویل اتوماتیک ✓ مقیاس پذیری فوری ✓ پرداخت به ازای مصرف

ارتباط با کارشناسان

رایگان شروع کنید

آروان کلاد

زیرساخت یکپارچه ابری و هوش مصنوعی جهانی امن‌تر، سریع‌تر و در دسترس‌تر

با استفاده از زیرساخت یکپارچه، پایدار، امن و هوشمند آروان‌کلاد، بدون دغدغه‌های زیرساختی به وبسایت‌ها و سرویس‌های خود سرعت ببخشید و تجربه‌ی کاربران‌تان را به شکل چشم‌گیری بهبود دهید.

تماس با فروش

شروع کنید

من از این دو پرو و ایدر استفاده می‌کنم.

ابر فردوسی

ابر فردوسی : برترین ارائه دهنده رایانش ابری در ایران

با ارائه قدرتمندترین سخت‌افزار ابری

میزبان ۲۰۰۰۰+ کسب و کار و پروژه هستیم.

✓ تحویل اتوماتیک ✓ مقیاس پذیری فوری ✓ پرداخت به ازای مصرف

ارتباط با کارشناسان

رایگان شروع کنید



زیرساخت یکپارچه ابری و هوش مصنوعی جهانی امن‌تر، سریع‌تر و دردسترس‌تر

با استفاده از زیرساخت یکپارچه، پایدار، امن و هوشمند آروان‌کلا، بدون دغدغه‌های زیرساختی به وبسایت‌ها و سرویس‌های خود سرعت ببخشید و تجربه‌ی کاربران‌تان را به شکل چشم‌گیری بهبود دهید.

تماس با فروش

شروع کنید

بهترین در دنیا. اگر اکانت دارین با این کار کنید.

ابرفردوسی : برترین ارائه دهنده رایانش ابری در ایران

با ارائه قدرتمندترین سخت‌افزار ابری

میزبان ۲۰۰۰۰+ کسب و کار و پروژه هستیم.

☒ تحویل اتوماتیک ☒ مقیاس پذیری فوری ☒ پرداخت به ازای مصرف

ارتباط با کارشناسان

رایگان شروع کنید

aws





محمد فزونی
دانشگاه گنبدکاووس

به امید روزهای خوب برای کشورمون

Iran

علی‌رغم تمامی مشکلات جاری
در کشور، امیدوارم که بتوانیم از
ته دل بخندیم.

چاره‌ای نداریم؛ جز ادامه دادن.

درباره مدرس

دکتر محمد فزونی

عضو هیئت علمی دانشگاه گنبدکاووس و دانشیار گروه ریاضی و آمار در این دانشگاه (مشاهده‌ی صفحه‌ی دانشگاهی بنده). از سال 1393 بطور رسمی وارد حرفه‌ی تدریس شدم و تا امروز و با افتخار بیش از هزاران دانشجو را در ایران و خارج از کشور تربیت نمودم. از دوران دبیرستان با کامپیوتر آشنا شدم. سال‌هاست در کنار درس و دانشگاه، پروژه‌های مختلف در حوزه‌های دیتا را اجرا و راهبری نموده‌ام.



**هر ابهامی داشتید در خدمت شما هستم؛ با افتخار.
من خودم از دوران دبیرستان (27 سال قبل)، منتور داشتم. یک منتور خفن.**